

API 基本資訊

- 路由端點 (Endpoint) : /cgi-bin/respond_invitation.py
- 請求方法 (HTTP Method) : POST
- 內容類型 (Content-Type) : application/json; charset=utf-8



請求參數規範 (Request Payload)

被邀請人 (例如小華的 App) 做出選擇時, 前端發送的 JSON 格式如下:

```
JSON
{
  "payload": {
    "invitation_id": 2,
    "invitee_uid": "target_user_88",
    "action": "Accepted"
  }
}
```

欄位詳細說明

欄位名稱	型態	必填	說明
invitation_id	Integer	是	邀請函的唯一流水號 (對應 family_invitations.id)。
invitee_uid	String	是	執行此操作的被邀請人帳號 (用於安全驗證, 防止越權操作)。
action	String	是	回應結果, 僅允許 'Accepted' (接受) 或 'Rejected' (拒絕)。

後端核心業務邏輯與驗證流程

當 CGI 接收到請求後，必須在事務(Transaction)內嚴謹執行以下流程：

1. 邀請函有效性驗證

查詢 family_invitations 表，確認該 invitation_id 存在：

- 防越權檢查：確認該邀請函的 invitee_uid 與目前發送請求的 invitee_uid 完全一致。不允許 A 用戶去幫 B 用戶接受邀請。
- 狀態檢查：該邀請函的 status 必須為 'Pending'。若已經是 'Accepted' 或 'Rejected'，直接攔截並提示「此邀請已處理過」。

2. 分流處理：當 action 為 'Rejected' (拒絕)

- 資料庫異動：將 family_invitations 表中的 status 更新為 'Rejected'。
- 地端連動：不需發送 MQTT 訊息，亦不更動 user_families 表。直接回傳成功。

3. 分流處理：當 action 為 'Accepted' (接受)

- 資料庫異動 A：將 family_invitations 表中的 status 更新為 'Accepted'。
- 資料庫異動 B (核心優化)：向 user_families 寫入權限關係。為了防止該用戶以前曾加入過 (留有 Revoked 紀錄)，必須使用冪等 Upsert 語法：

SQL

```
INSERT INTO user_families (user_id, family_id, role)
VALUES % % %
ON DUPLICATE KEY UPDATE role = VALUES (role);
```

- 地端實時同步：通過資料庫後，立即使用 paho.mqtt.publish.single() 向地端廣播權限生效通知：
 - Topic: home/security/gateway_{family_id}/auth_sync
 - Payload:

JSON

```
{
  "event": "MEMBER_ADDED",
  "user_data": {
    "user_id": "target_user_88",
    "role": "Member" // 或者是 Guest, 動態對齊邀請函內的設定
  }
}
```

回應規範 (Responses)

1. 成功回應 (200 OK)

- 情境 A: 接受邀請成功

```
JSON
{
  "status": "Success",
  "msg": "已接受邀請, 新成員權限已實時同步至地端閘道器"
}
```

- 情境 B: 拒絕邀請成功

```
JSON
{
  "status": "Success",
  "msg": "已拒絕該家庭的邀請"
}
```

2. 失敗回應 (Error Responses)

- 案例 A: 試圖操作別人的邀請函 (403 Forbidden)

```
JSON
{
  "status": "Error",
  "msg": "安全錯誤: 您無權操作此操作此邀請函"
}
```

- 案例 B: 邀請函不存在 (404 Not Found)

```
JSON
{
  "status": "Error",
  "msg": "找不到該邀請紀錄"
}
```

- 案例 C: 炒冷飯, 重複處理已失效的邀請 (422 Unprocessable Entity)

```
JSON
{
  "status": "Error",
  "msg": "該邀請函已被處理過或已過期"
}
```



cURL 模擬測試指令

測試 1: 模擬小華「接受」邀請

```
Bash
curl -X POST \
  -H "Content-Type: application/json" \
  -d '{
    "payload": {
      "invitation_id": 2,
      "invitee_uid": "target_user_88",
      "action": "Accepted"
    }
  }' \
  http://localhost/cgi-bin/respond_invitation.py
```

測試 2: 模擬小明「拒絕」邀請

```
Bash
curl -X POST \
  -H "Content-Type: application/json" \
  -d '{
    "payload": {
      "invitation_id": 1,
      "invitee_uid": "target_user_99",
      "action": "Rejected"
    }
  }' \
  http://localhost/cgi-bin/respond_invitation.py
```